Cos'è una DMZ (Demilitarized Zone)

Una **DMZ** è una **rete separata** posta tra la rete interna (LAN) e Internet (WAN), progettata per ospitare servizi che devono essere accessibili dall'esterno, senza esporre direttamente la LAN.

Obiettivo:

- separare i sistemi pubblici (es. web server) dalla rete interna
- ridurre l'impatto di una compromissione

La DMZ è una **zona di rete distinta**, con propria subnet IP, proprie regole firewall e routing controllato.

Tipologie effettivamente usate

Le implementazioni realmente diffuse sono tre:

1. DMZ a 3 interfacce (single firewall)
2. DMZ con doppio firewall (dual firewall)
3. "DMZ" domestica (funzione semplificata nei router SOHO)

---

1) DMZ a 3 interfacce (architettura più comune in ambito aziendale)

Struttura hardware:

Firewall con 3 interfacce fisiche:

- NIC1 → WAN (Internet)
- NIC2 → LAN interna
- NIC3 → DMZ

Collocazione componenti:

WAN

- Router ISP
- Internet

Firewall (dispositivo fisico unico)

- Interfaccia WAN
- Interfaccia LAN
- Interfaccia DMZ
- NAT
- Firewall stateful
- Routing tra le 3 zone
- Eventuale IPS/IDS

DMZ (rete separata)

- Web server
- Mail server
- Reverse proxy
- Server DNS pubblico

LAN

- PC aziendali
- File server interni
- Database non esposti

Logica di funzionamento:

- WAN → DMZ: consentito solo traffico verso servizi pubblici (es. TCP 443)
- WAN → LAN: bloccato
- DMZ → LAN: normalmente bloccato o fortemente limitato
- LAN → DMZ: consentito
- LAN → WAN: consentito con NAT

Il firewall è il punto centrale di controllo.

---

2) DMZ con doppio firewall (maggiore isolamento)

Struttura hardware:
Internet | Firewall esterno | DMZ | Firewall interno | LAN

Collocazione componenti:

Firewall esterno

- Interfaccia WAN
- Interfaccia DMZ
- NAT pubblico
- Regole Internet → DMZ

DMZ

- Server pubblici

Firewall interno

- Interfaccia DMZ
- Interfaccia LAN
- Filtri DMZ → LAN

Vantaggio:

- Se compromesso il firewall esterno, la LAN è ancora protetta dal firewall interno.

È una soluzione usata in ambienti ad alta sicurezza.

---

3) "DMZ" nei router domestici (SOHO)

Nei router casalinghi la voce "DMZ" NON è una vera zona di rete separata.

È semplicemente:

- una regola NAT che inoltra tutto il traffico in ingresso verso un singolo IP interno.

Collocazione reale:

LAN

- PC 192.168.1.100 (esposto)

Router domestico

- NAT
- Firewall base
- Regola "DMZ host" → inoltra tutte le porte verso 192.168.1.100

WAN

- Internet

Non esiste una subnet separata. Non esiste isolamento reale dalla LAN. È solo un port forwarding totale.

Componenti hardware e logici – dove sono collocati

Firewall (hardware o appliance virtuale)

- Posizione: confine tra zone (WAN/DMZ/LAN)
- Funzione: filtraggio, NAT, routing

Switch DMZ

- Posizione: rete DMZ

- Funzione: collegare server pubblici

Server pubblici

- Posizione: subnet DMZ
- IP dedicati (privati o pubblici)

NAT

- Posizione: firewall (tra WAN e DMZ o WAN e LAN)

Routing

- Posizione: firewall e router ISP

Reverse proxy

- Posizione: server nella DMZ

WAF

- Posizione: nella DMZ (davanti ai server web) oppure integrato nel firewall

DNS pubblico

- Posizione: DMZ o cloud esterno

Flussi tipici

Internet → DMZ

- Consentito solo verso servizi pubblici

Internet → LAN

- Bloccato

DMZ → LAN

- Bloccato (salvo eccezioni controllate)

LAN → DMZ

- Consentito

LAN → Internet

- Consentito con NAT

Esempio 1 – Piccola azienda con DMZ a 3 interfacce

Rete ISP

- IP pubblico: 203.0.113.10

Firewall:

- WAN: 203.0.113.10
- DMZ: 192.168.10.1/24
- LAN: 192.168.1.1/24

DMZ:

- Web server: 192.168.10.10
- Mail server: 192.168.10.20

LAN:

- PC1: 192.168.1.100
- DB server: 192.168.1.200

Regole:

- NAT 203.0.113.10:443 → 192.168.10.10:443

- WAN → LAN: negato
- DMZ → LAN: negato

Esempio 2 – Router domestico con "DMZ host"

Router:

- WAN: 93.45.67.80
- LAN: 192.168.1.1/24

PC gaming:

- 192.168.1.50

Impostazione "DMZ":

- Tutto il traffico in ingresso su 93.45.67.80 → inoltrato a 192.168.1.50

Non esiste subnet separata. Il PC è direttamente esposto a Internet tramite NAT completo.

---

diagrammi delle tre architetture con evidenziazione delle zone e dei flussi consentiti/bloccati.

Di seguito sono forniti **diagrammi per le tre principali architetture DMZ** utilizzate nei contesti reali: singolo firewall con tre interfacce, doppio firewall (dual firewall), e la "DMZ host" semplificata dei router domestici.

1) Architettura DMZ con singolo firewall (Three-legged)

Questa configurazione prevede un **firewall con tre interfacce** distinte:

- WAN verso Internet
- DMZ verso la sottorete pubblica
- LAN verso la rete interna Il firewall gestisce **routing, filtraggio delle connessioni e NAT** tra tutte e tre le zone. (Wikipedia)

Zone e dispositivi tipici

```
Internet
  |
 Firewall (interface WAN)
  |---------- (interface DMZ) ----> Server pubblici (es. web, mail)
  |
 (interface LAN) ----> Rete interna (workstation, DB)
```

In questo modello il firewall è il **punto centrale di controllo** per tutte le connessioni entranti e uscenti.

2) Architettura DMZ con doppio firewall (Dual Firewall)

In questa configurazione si usano **due firewall separati**:

- Firewall esterno tra Internet e DMZ
- Firewall interno tra DMZ e LAN Questo aumenta l'isolamento: se il firewall esterno è compromesso non si accede direttamente alla LAN. (Edrawsoft)

Zone e dispositivi tipici

```
Internet
  |
Firewall esterno
  |
  ---> DMZ (server web, mail, DNS)
  |
Firewall interno
  |
LAN (workstation, database, file server)
```

I server pubblici sono collocati fisicamente nella subnet DMZ, separata dalla rete interna e controllata da due livelli di firewall.

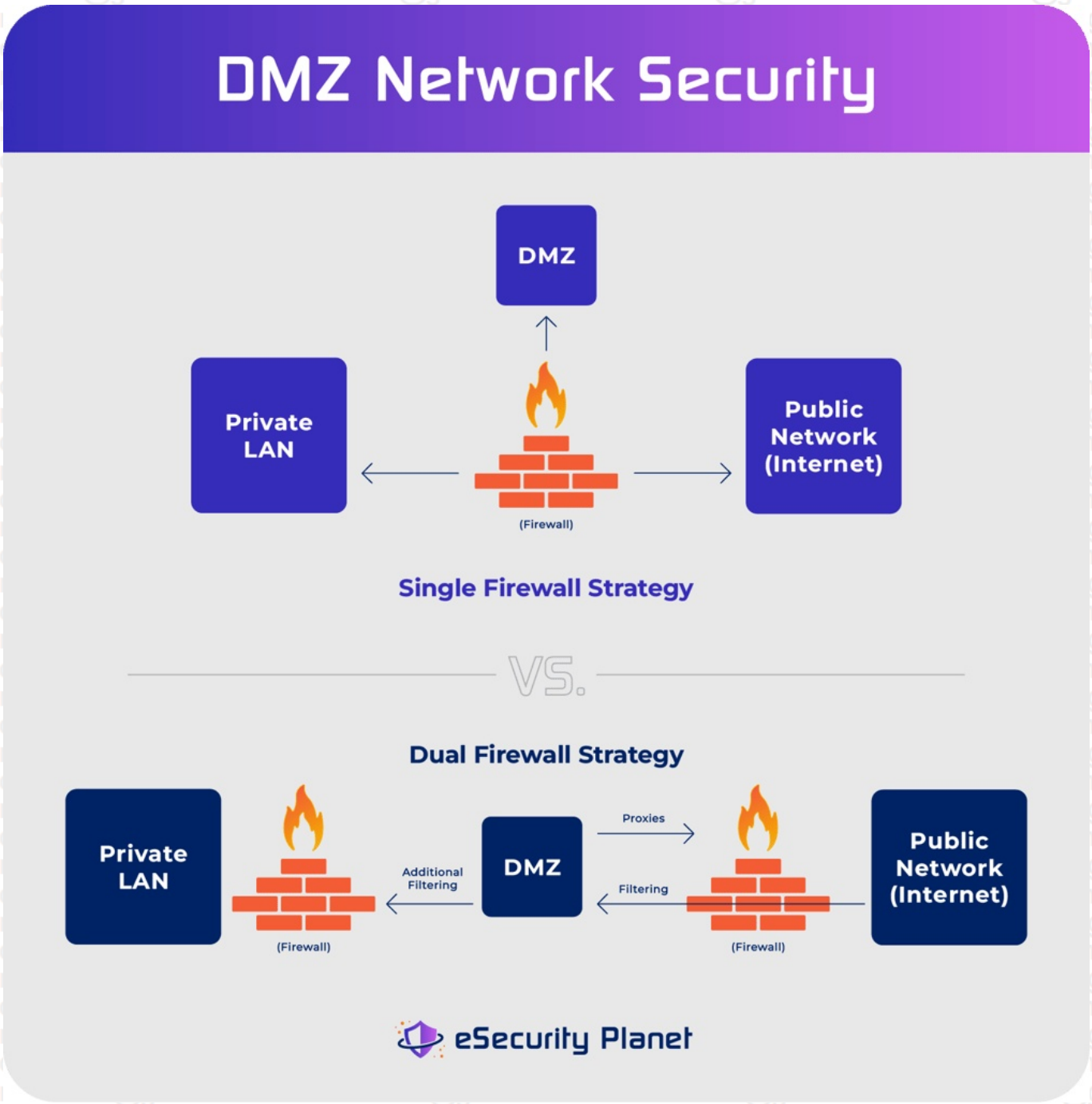

Figure 1: Image

© enrico.viali@gmail.com

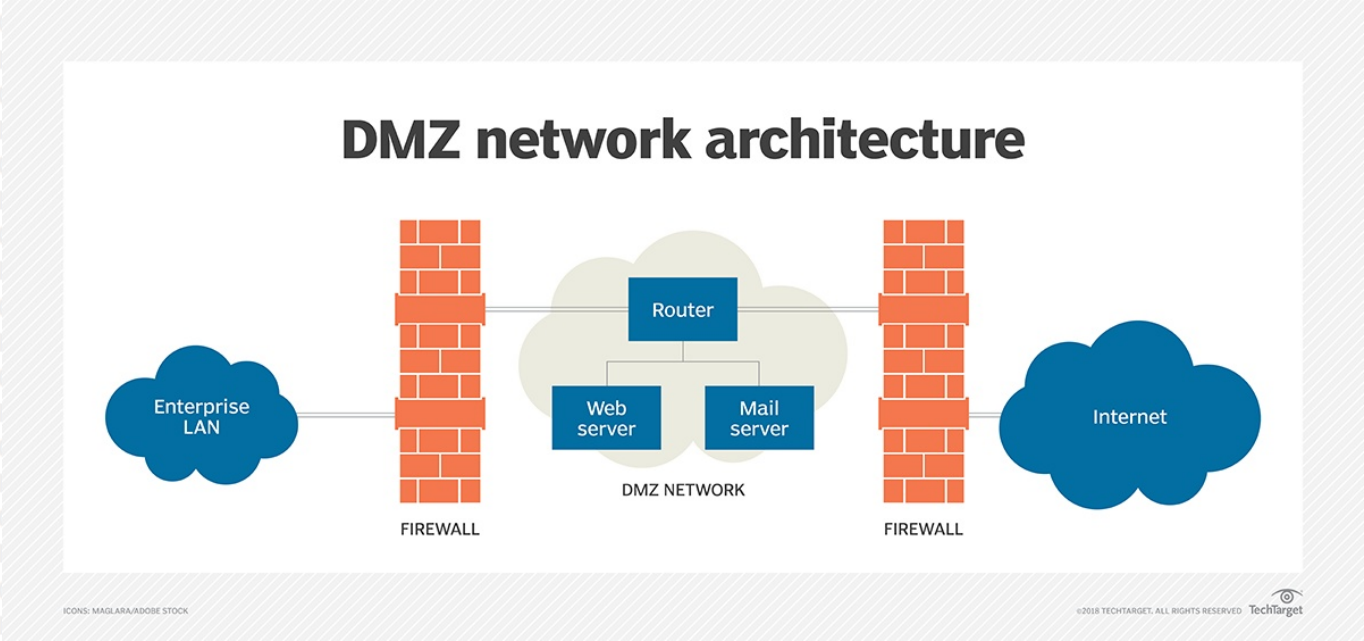

Figure 2: Image

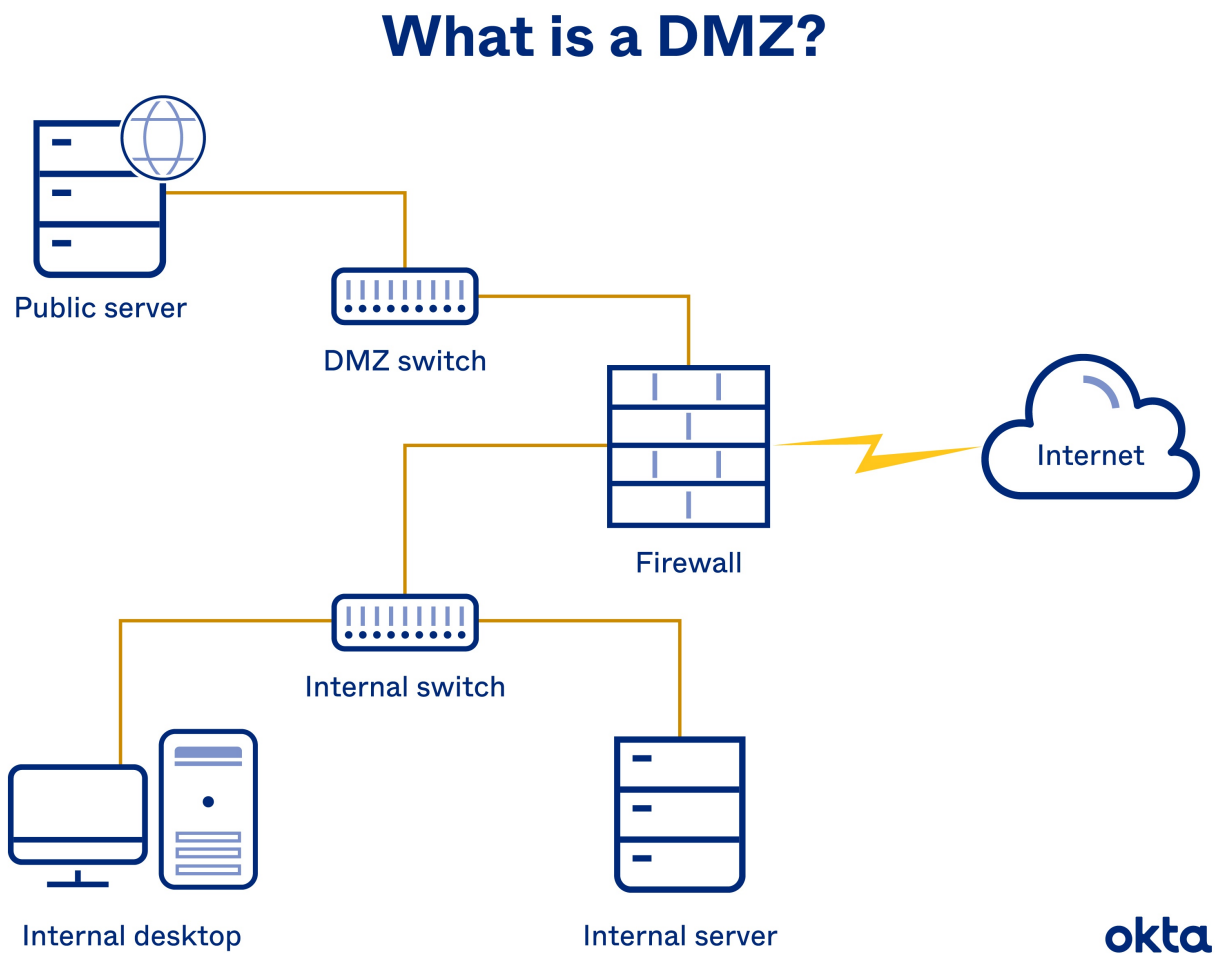

Figure 3: image_4

© enrico.viali@gmail.com

Two Firewalls, One DMZ

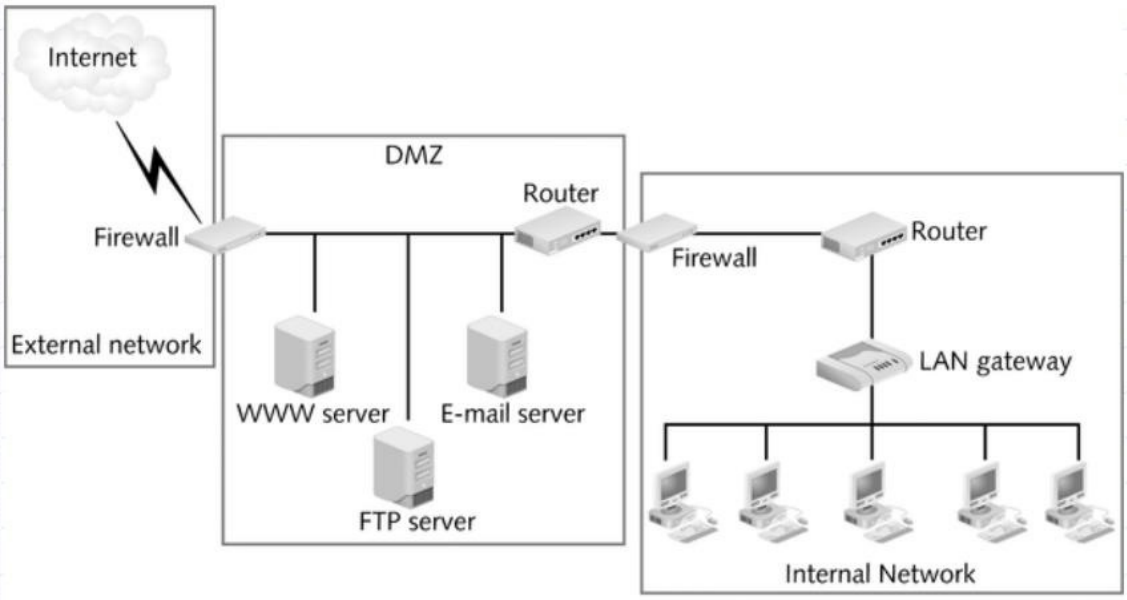

Figure 3-6 Two firewalls enclose the DMZ to protect the internal network

Figure 4: Image

3) DMZ “host” nei router domestici

Nei router casalinghi la voce “DMZ” **non crea una subnet separata**. È semplicemente:

- un **inoltro completo di tutte le porte** dalla WAN verso un singolo dispositivo interno
- il router mantiene l’unica LAN

In realtà non è una DMZ isolata ma un **host esposto al pubblico tramite NAT**. (Wikipedia)

Struttura semplificata

```
Internet
   |
Router domestico (WAN   LAN)
   |--- NAT totale verso 192.168.1.50 (host DMZ)
LAN (altri dispositivi)
```

In questo caso non esiste isolamento mediante subnet o firewall separati per una zona DMZ.

Se si desidera posso fornire **diagrammi in stile testo puro (ASCII o SVG)** per uso in documentazione tecnica o presentazioni.

© enrico.viali@gmail.com